

Cameroon HRIS authority-evidence module design

Employment, statutory provenance, governance authority and G1 approval readiness

CAMEROON HRIS / PAYROLL AUTHORITY EVIDENCE

Prepared 2026-08-19

Evidence-led · bilingual-ready · accessibility-aware · implementation-bounded

Connected operations. Explicit controls. Inspectable evidence.

Prepared 2026-08-19 Status: **PROPOSED — G1-FOCUSED — NOT IMPLEMENTED** LEGAL REVIEW REQUIRED — not a legal-compliance certification.

Architecture decision

Build the first version as a **bounded module inside the existing Stoquify application**, not a separate network service. It should reuse the current Prisma transaction boundary, tenant resolver, RBAC, session assurance, audit/security events and HRIS effective-dating. Keep provider adapters behind interfaces so the module can be extracted later if scale, legal isolation or integration volume justifies it.

This boundary minimizes distributed failure modes while the first use case is only 17 roles, 33 obligations and one frozen G1 contract.

Responsibility boundary

Identity link resolver	Verified User.id ↔ PayrollEmployee.id binding	Match by display name/email alone
Employment evidence registry	Contract/CNPS/employer-register references, hashes, issuer and verification	Declare a control role
HR assignment resolver	Effective position, unit and employment status	Grant G1 authority automatically
Authority catalog	Versioned canonical roles and permitted scopes	Reuse mutable job titles or ordinary RBAC role labels
Authority assignment/delegation	Appointment issuer, subject, scope, dates, evidence and revocation	Perform a human approval
SoD/COI evaluator	Policy-versioned conflict result and independent checker	Self-certify evidence it produced
Eligibility engine	Fail-closed current eligibility read model	Treat authentication as authorization
Approval envelope	Exact decision/option/contract binding, fresh auth and deliberate intent	Accept UI-only success
Independent verifier	Resolve artifacts, rehash, compare and record pass/fail	Edit producer evidence silently
External adapter	CNPS/DGI/e-sign provider-neutral ingestion	Make unverified provider data authoritative

Proposed data model

Reuse User, Session, PayrollEmployee, HrisOrgUnit, HrisPosition, HrisEmploymentAssignment, HrisReportingRelationship, BusinessEvent and AuditLog.

Add only after Phase 0 governance approval:

- 1 `HrisIdentityEmploymentEvidence` — subject, employee, evidence type, issuer, URI, SHA-256, validity, producer and independent verifier.
- 2 `ControlAuthorityRole` — immutable/versioned canonical role code, domain, allowed decision/capability scope and qualification rule.
- 3 `ControlAuthorityAssignment` — subject/employee/role/tenant/scope/effective dates, appointing authority, appointment evidence hash and status.
- 4 `ControlAuthorityDelegation` — bounded role/decision scope, delegator, delegate, mandatory expiry, reason/evidence hashes, revocation and supersession.

- 5 `ControlSodAssessment` — assignment set, policy version/hash, result, conflicts, exception reference, independent reviewer and expiry.
- 6 `ControlQualificationEvidence` — qualification type, issuing body, jurisdiction, scope, expiry, evidence and verification.
- 7 `ControlApprovalEnvelope` — contract and policy hashes, decision/option, required roles, status and invalidation state.
- 8 `ControlApprovalAttestation` — signer subject, authority snapshot, fresh-auth evidence, intent, timestamp and immutable signature/evidence reference.
- 9 `ControlEvidenceVerification` — producer/verifier separation, resolved bytes hash, expected hash, result and timestamp.
- 10 `ControlInvalidationEvent` — append-only cause linking employment, authority, policy or artifact drift to affected eligibility/approvals.

Do not overload `HrisManagerDelegation.APPROVAL_DECISION`: it lacks the exact canonical control role and decision/contract scope required by G1.

State model

SOURCE_MISSING → SOURCE_CAPTURED → SOURCE_VERIFIED → EMPLOYMENT_VERIFIED →
 AUTHORITY_APPOINTED → SOD_CLEARED → ELIGIBLE_TO_APPROVE →
 APPROVED_PENDING_VERIFICATION → VERIFIED_APPROVAL

Any drift produces `INVALIDATED`; ambiguous evidence produces `BLOCKED`, never a soft pass.

APIs

POST	<code>/internal/hris/evidence/intake</code>	Register metadata and expected hash; no authority yet	HR permission, tenant scope, idempotency
POST	<code>/internal/hris/evidence/:id/verify</code>	Independent artifact resolution/rehash	Verifier permission, producer ≠ verifier
POST	<code>/internal/control-authority/assignments</code>	Create pending appointment from verified evidence	Governance permission, fresh auth, issuer authority
POST	<code>/internal/control-authority/assignments/:id/activate</code>	Activate after SoD/COI/qualification	Independent checker, policy hash
POST	<code>/internal/control-authority/delegations</code>	Create bounded temporary delegation	Eligible delegator, mandatory expiry, fresh auth
POST	<code>/internal/control-authority/:id/revoke</code>	Revoke and invalidate dependents	Governance/HR event, reason hash
GET	<code>/internal/control-authority/eligibility</code>	Resolve current role/decision eligibility	Tenant scoped, fail closed
POST	<code>/internal/g1/envelopes/:decisionId/approve</code>	Deliberate human approval	Eligible role, fresh auth ≤10 minutes, exact hashes
POST	<code>/internal/g1/attestations/:id/verify</code>	Independent final evidence verification	Verifier separation, content rehash
GET	<code>/internal/g1/export</code>	Build minimal detached register candidate	All required attestations verified; no direct live write

Service/API checks, not the UI, determine success. UI controls are guidance only.

Events

- 1 `hris.identity_employment_evidence.verified`
- 1 `hris.employment_assignment.changed`
- 1 `control.authority_assignment.activated|revoked|expired`
- 1 `control.delegation.activated|revoked|expired`
- 1 `control.sod_assessment.completed|invalidated`
- 1 `control.approval_attestation.recorded|verified|invalidated`
- 1 `control.artifact_drift.detected`

Every event carries tenant, actor, subject, source IDs, payload hash, policy/contract hash and correlation/idempotency key. It must exclude raw national IDs, CNPS numbers, passwords, tokens and unneeded medical data.

Fresh authentication

The repository already supports session-bound password step-up and `requireFreshAuth`. G1 should call it with the approved maximum age and additionally bind signer, tenant, session, decision, option and contract hash. Whether password-only assurance is sufficient is unresolved; the proposed policy default is MFA for activation, delegation, approval and evidence verification, subject to security/governance approval.

SoD policy baseline

- 1 Evidence producer cannot be the independent verifier.
- 1 Appointment subject cannot verify their own appointment.
- 1 Delegator cannot equal delegate; the existing schema already enforces this for manager delegations.
- 1 Maker/checker and signer/verifier combinations fail unless an explicit, independently approved exception exists.
- 1 A person may hold multiple business roles only if the exact role pair and decisions are approved by policy; distinct names alone do not prove a pass.
- 1 Qualified Cameroon and accounting reviewer roles require current qualification evidence, not ordinary application permissions.

Threat model

Identity confusion	Candidate/display name mapped to wrong account	Stable subject ID, HR cross-check, tenant binding, independent verification
Authority laundering	Job title/RBAC role treated as control appointment	Separate versioned authority catalog and signed appointment
Evidence substitution	Path content changes after approval	Content-addressed URI, SHA-256, immutable version and rehash
Self-certification	Producer approves/verifies own artifact	Database/service SoD constraints and verifier permission
Replay after drift	Old approval reused for new contract/policy	Exact contract/policy hash and invalidation events
Cross-tenant access	Evidence or authority resolved in wrong organization	Tenant in every key/query/event; deny and audit mismatch
Session theft/stale auth	Approval uses old or wrong session	Fresh auth, session/subject/tenant match, revocation and short window
Provider spoofing	Fake CNPS/e-sign callback	Allowlisted adapter, signature validation, idempotency and independent reconciliation
PII leakage	National/CNPS/medical data appears in reports/logs	Masking, keyed hashes, field-level permissions, redaction and retention
UI bypass	Direct API creates pass without checks	Server-side state machine and database transaction; UI never authoritative

UI

Provide a role-aware command center with four separate statuses: Employment, Authority, Conflict review and Approval. Display blocker reasons and next owners. Never show “approved” because a name or image was entered. Sensitive evidence opens only through audited, expiring access grants.

Observability

Track evidence-verification failures, stale appointments, delegations near expiry, conflict failures, cross-tenant denials, failed fresh-auth attempts, artifact drift, invalidations and time-to-resolve. Alert on any transition to eligible/verified that lacks a complete event chain.

Adapter strategy

Start with controlled manual upload and independent verification. Add CNPS/DGI read or submission adapters only with documented authority and stable supported interfaces. Add external e-signature through a provider-neutral envelope adapter; internal operational approval must continue to work without a full e-signature platform.

Reuse beyond G1

The same evidence/authority primitives can support payroll compensation, payment-destination changes, purchasing/AP, inventory write-offs, reconciliations, country-pack reviews and close certification. Domain services remain owners of business truth; the control module only proves identity, authority, evidence and approval state.